

Mustafa Hasan

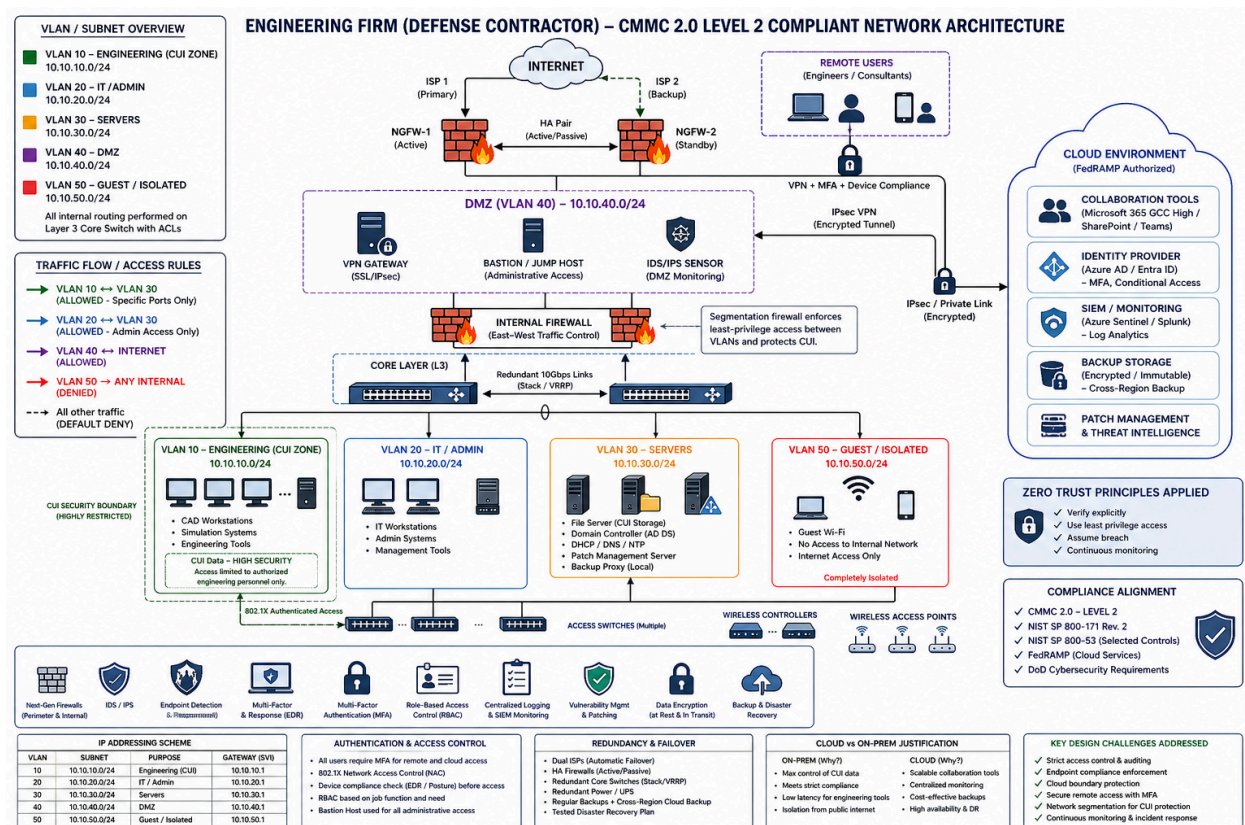
ITMO 340

Final Project

4/30/2026

I chose Scenario 3: Engineering Firm with CUI (Defense Contractor)

Diagram:



Explanation:

In this network design, a secure system was created for a small engineering firm that works with sensitive government data, also known as Controlled Unclassified Information (CUI). The main goal of this design was to ensure the network is secure, reliable, and follows proper cybersecurity standards like CMMC 2.0. At the very top of the diagram, the Internet is used as the starting point, which connects to two different Internet Service Providers. Two ISPs were included

instead of one so that if one connection fails, the network can still stay online. This improves reliability and reduces downtime. After that, all incoming traffic goes through a pair of firewalls. These are next-generation firewalls configured in a high-availability setup, meaning one is active, and the other serves as a backup. These firewalls are important because they filter traffic, block malicious activity, and act as the first layer of security for the network. Right after the firewall, a DMZ (Demilitarized Zone) was created, which is separated as its own network (VLAN 40). The DMZ functions as a buffer zone between the Internet and the internal network. In this area, the VPN gateway, a bastion host, and an IDS/IPS system are placed. Remote users, such as engineers or consultants, must connect through the VPN using multi-factor authentication before accessing anything. Devices are also checked to ensure they are secure. The bastion host acts as a controlled entry point so users do not directly access internal systems, which adds another layer of protection. Behind the DMZ, an internal firewall is added. This firewall is used to control traffic inside the network, especially between different sections (VLANs). This is important because it enforces rules on who can access what and follows the principle of least privilege. The internal network is connected through a Layer 3 core switch, which handles routing between different VLANs. The network is divided into multiple VLANs to keep everything organized and secure. The most important one is VLAN 10, labeled as the CUI zone. This network contains engineering systems like CAD workstations and simulation tools. Since this data is sensitive, this VLAN is highly restricted and only accessible to authorized users. VLAN 20 is used for IT and admin staff. These users manage the system but do not have direct access to sensitive engineering data unless needed. VLAN 30 contains servers, including file servers where CUI data is stored, domain controllers for authentication, and systems for updates and patching. Communication between VLAN 10 and VLAN 30 is allowed,

but only for specific purposes. VLAN 50 is the guest network, and it is completely isolated. Devices on this network can only access the Internet and cannot connect to any internal systems. This prevents unauthorized access from outside users. A cloud environment using a platform such as Microsoft Azure is also included. The cloud is used for collaboration tools, backups, identity management, and security monitoring. The connection between the cloud and the internal network is encrypted using a secure VPN. Remote users must go through VPN, use multi-factor authentication, and pass device security checks before accessing any resources. This follows a Zero Trust approach, where no user is trusted by default. Finally, redundancy features such as dual ISPs, backup firewalls, and cloud backups are included to ensure the system stays running even if something fails.

Architecture Overview

This project presents a secure network architecture for a small engineering firm that handles Controlled Unclassified Information (CUI). The primary goal of the design is to protect sensitive data, provide secure collaboration, and meet CMMC 2.0 Level 2 requirements. The network follows a hybrid architecture, combining on-premises infrastructure with cloud services. Sensitive systems, including engineering workstations and CUI data storage, are kept on-premises to maintain strict control and reduce exposure. Cloud services are used for identity management, monitoring, collaboration, and backups to improve scalability and availability. The overall design is based on Zero Trust principles, meaning no user or device is trusted by default, and every access request must be verified using identity, device health, and access policies before access is granted.

Network Design & Segmentation

To improve both security and performance, the network is divided into multiple VLANs, each with its own subnet. VLAN 10 is the Engineering (CUI Zone) using 10.10.10.0/24, VLAN 20 is IT/Admin using 10.10.20.0/24, VLAN 30 is Servers using 10.10.30.0/24, VLAN 40 is the DMZ using 10.10.40.0/24, and VLAN 50 is the Guest/Isolated network using 10.10.50.0/24. This segmentation isolates sensitive systems and limits how traffic flows across the network.

Engineering systems in VLAN 10 can only access required services on the server network in VLAN 30, such as file storage and authentication. IT/Admin systems in VLAN 20 are allowed controlled administrative access to servers, while the guest network in VLAN 50 is completely isolated and restricted to Internet-only access. Routing between VLANs is handled by a Layer 3 core switch and controlled by an internal firewall, which enforces strict access policies based on the least privilege principle, preventing unauthorized lateral movement within the network.

IP Addressing

A private IP addressing scheme is used to organize and manage the network efficiently. Each VLAN is assigned a dedicated subnet: VLAN 10 uses 10.10.10.0/24, VLAN 20 uses 10.10.20.0/24, VLAN 30 uses 10.10.30.0/24, VLAN 40 uses 10.10.40.0/24, and VLAN 50 uses 10.10.50.0/24. Default gateways are configured on the Layer 3 switch as 10.10.X.1, allowing controlled inter-VLAN routing. This structure simplifies management, improves scalability, and supports strong access control enforcement.

Security Controls

A layered security model (defense-in-depth) is implemented across the network. For perimeter security, dual next-generation firewalls filter inbound and outbound traffic and are configured in high availability (active/passive) for reliability, protecting against external threats and unauthorized access. The DMZ (Demilitarized Zone) hosts a VPN gateway, bastion (jump) host,

and IDS/IPS sensor, acting as a buffer between the Internet and internal systems and preventing direct exposure of internal resources. Internal security for east-west traffic control is enforced through an internal firewall that segments VLANs and prevents lateral movement inside the network. Endpoint security is maintained through Endpoint Detection and Response (EDR), ensuring device security and requiring device compliance checks before access. Data protection is achieved through encryption of data at rest for file servers and backups, as well as encryption of data in transit using VPN and secure protocols. Monitoring and logging are handled by a cloud-based SIEM that collects logs, detects suspicious activity, and enables real-time monitoring and alerting. Example access control rules include VLAN 10 to VLAN 30 being allowed only for required services such as file access and authentication, VLAN 20 to VLAN 30 being allowed for administrative protocols such as RDP and SSH, VLAN 50 being denied access to internal networks, and all other traffic following a default deny policy.

Authentication & Access Control

Strong identity and access management controls are implemented across the system.

Multi-Factor Authentication (MFA) is required for all users, and Role-Based Access Control (RBAC) limits access based on job roles. A centralized identity provider, such as Azure AD or Active Directory, is used, and conditional access policies enforce device compliance and login conditions. Remote users must connect through a secure VPN (IPSec/SSL) and pass MFA and device security checks before accessing resources. Administrative access is restricted through a bastion host, which prevents direct access to critical systems and reduces attack surfaces.

Cloud & On-Prem Integration

The architecture uses a hybrid model to balance security and flexibility. On-premises systems include engineering workstations in the CUI zone, file servers storing sensitive data, and core

network infrastructure. Cloud services include collaboration tools such as Microsoft 365, identity management through Azure AD, SIEM, and monitoring tools such as Azure Sentinel or Splunk, and backup and disaster recovery services. The on-premises network connects to the cloud through an encrypted site-to-site VPN or private link, ensuring secure communication without exposing sensitive data to the public Internet.

Redundancy and Failover Design

To ensure high availability, multiple redundancy mechanisms are implemented. These include dual ISPs for Internet failover, a high-availability firewall pair operating in active/passive mode, redundant core switches using stacking or VRRP, regular backups using both local and cloud storage, and a disaster recovery plan with tested restoration procedures. These measures reduce downtime and ensure business continuity in case of failures.

Incident Response

The network includes an integrated incident response process. Threats are detected through IDS/IPS and SIEM systems, and alerts are generated and sent to IT and security staff. Affected systems are isolated to prevent spread, logs are analyzed to determine the cause, and systems are restored using secure backups if needed. This process ensures quick detection, containment, and recovery from security incidents.

Cloud vs On-Prem Justification

Sensitive systems handling CUI are kept on-premises to maintain strict control, meet compliance requirements, and reduce exposure to external risks. Cloud services are used for scalability, centralized monitoring, and cost efficiency. For example, cloud-based backups eliminate the need for additional physical storage, and cloud SIEM tools provide advanced monitoring without

requiring dedicated hardware. This hybrid approach balances security, performance, and cost-effectiveness.

Compliance Considerations (CMMC 2.0 Level 2)

This design aligns with CMMC 2.0 Level 2 and NIST SP 800-171 by implementing key security controls. Access Control (AC) is enforced through VLAN segmentation, RBAC, and VPN restrictions. Identification and Authentication (IA) is handled through MFA and centralized identity management. Audit and Accountability (AU) is achieved through SIEM logging and monitoring. System and Communications Protection (SC) is enforced through firewalls and encrypted communication. Incident Response (IR) is implemented through detection, alerting, and recovery processes. These controls ensure that CUI is protected and that the organization meets required cybersecurity standards.

Optional Enhancements (Extra Credit)

Zero Trust Architecture is implemented by requiring verification for every user and device. Access is granted based on identity, role, and device health, reducing the risk of unauthorized access, while continuous monitoring ensures that threats are detected quickly. Cost estimation shows that the hybrid design reduces costs while maintaining security. Cloud backups eliminate the need for additional on-site storage, cloud-based monitoring reduces infrastructure and maintenance costs, and scalable services allow pay-as-you-go usage. This approach ensures cost efficiency without compromising security. The implementation timeline is structured in phases: Week 1 includes network setup, such as VLANs, switches, and IP addressing. Week 2 covers firewall configuration and segmentation. Week 3 involves VPN, MFA, and identity integration. Week 4 includes cloud services integration, such as SIEM and backups. Week 5 is dedicated to testing and validation. This phased approach ensures proper configuration and reduces

deployment risks. Incident response integration ensures that security monitoring tools such as SIEM and IDS/IPS are directly connected to incident response processes. Alerts trigger immediate investigation, system isolation, and recovery using backups, ensuring minimal impact from security events.

Conclusion

This network design provides a secure, scalable, and compliant solution for a defense contractor handling CUI. By combining strong segmentation, layered security controls, Zero Trust principles, and hybrid cloud integration, the architecture effectively protects sensitive data while supporting business operations. The design meets CMMC 2.0 Level 2 requirements and ensures reliability through redundancy and failover mechanisms.